

**Министерство науки и высшего образования Российской Федерации
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ
УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО**

Факультет безопасности информационных технологий

Дисциплина:
«Web программирование»

ОТЧЕТ ПО ЛАБОРАТОРНОЙ РАБОТЕ
«Hello, Secure World»

Выполнил:

Суханкулиев Мухаммет,
студент группы N3346



(подпись)

07.09.2025

Дата

Проверил:

Чернышев Вячеслав Алексеевич,
преподаватель по Web программированию

(отметка о выполнении)

(подпись)

Санкт-Петербург
2025 г.

СОДЕРЖАНИЕ

Введение.....	4
1 Hello, Secure World	5
1.1 Порядок запуска.....	5
1.2 Описание архитектуры, кода.....	5
1.3 Проверка результата.....	6
Заключение.....	7
Список использованных источников.....	8

ВВЕДЕНИЕ

Цель работы – освоить базовые механизмы создания веб-приложений на FastAPI, реализовать механизм добавления защитных HTTP-заголовков (CSP и HSTS), а также проверить корректность их работы с помощью ручного тестирования.

Для достижения поставленной цели необходимо решить следующие задачи:

- Реализовать FastAPI-сервис с одним маршрутом GET /ping, возвращающий JSON-ответ;
- Добавить middleware для установки заголовков Content-Security-Policy (CSP) и Strict-Transport-Security (HSTS);
- Запустить приложение локально и выполнить проверку ответа через curl.

1 HELLO, SECURE WORLD

Разработанный сервис «Hello, Secure World» представляет собой минимальное веб-приложение на FastAPI с единственным маршрутом GET /ping, возвращающим простой JSON-ответ.

- **Content-Security-Policy (CSP)** ограничивает загрузку ресурсов только текущим доменом. Это снижает вероятность XSS-атак, когда злоумышленник внедряет и выполняет сторонний код в браузере. При отсутствии CSP браузер будет загружать и выполнять любые подключённые ресурсы.

- **HTTP Strict-Transport-Security (HSTS)** принуждает браузеры всегда использовать HTTPS при обращении к серверу, включая поддомены, и разрешает предзагрузку правила. Это защищает пользователей от атак типа «человек посередине», при которых трафик может быть перехвачен или подменён.

1.1 Порядок запуска

1. Распаковать архив проекта `hello_secure_world.zip` и в терминале перейти в его директорию.

2. Создать и активировать виртуальное окружение для изоляции зависимостей:

```
python -m venv venv
venv\Scripts\activate # Windows
source venv/bin/activate # Linux / macOS
```

3. Установить минимально необходимые библиотеки из файла `requirements.txt`:

```
pip install -r requirements.txt
```

или

```
pip install fastapi[standard]
```

4. Запустить сервер (по умолчанию находит `main.py` и запускает на `0.0.0.0:8000`):

```
fastapi run
```

Ctrl+C для завершения работы сервера.

1.2 Описание архитектуры, кода

Приложение состоит из одного файла `main.py`. Оно построено на базе асинхронного фреймворка FastAPI, который работает поверх ASGI-сервера Uvicorn.

Объект приложения FastAPI (`app`): Точка входа, к которой привязываются маршруты и `middleware`.

Функция `security_headers`, декорированная `@app.middleware("http")`, перехватывает каждый ответ перед его отправкой клиенту и добавляет два заголовка: `Strict-Transport-Security` и `Content-Security-Policy` с заданными параметрами:

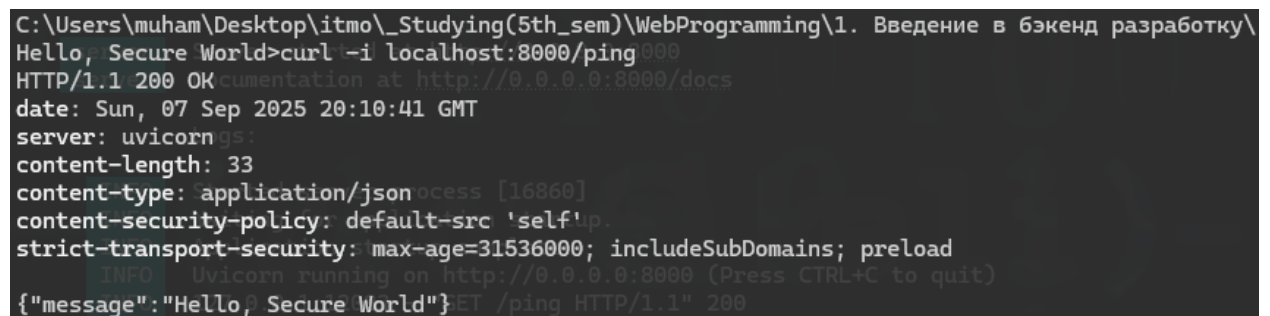
```
response.headers["Content-Security-Policy"] = "default-src 'self'"
response.headers["Strict-Transport-Security"] = ("max-age=31536000;
includeSubDomains; preload")
```

Функция `ping`, привязанная к маршруту `GET /ping`, возвращает стандартный Python-словарь. FastAPI автоматически и наиболее эффективно преобразует его в `JSONResponse`.

1.3 Проверка результата

Проверка корректности работы сервиса производилась с помощью `curl` с флагом `-i` для отображения заголовков в ответе:

```
curl -i localhost:8000/ping
```



```
C:\Users\muham\Desktop\itmo\_Studying(5th_sem)\WebProgramming\1. Введение в бэкенд разработку\
Hello, Secure World>curl -i localhost:8000/ping
HTTP/1.1 200 OK
documentation at http://0.0.0.0:8000/docs
date: Sun, 07 Sep 2025 20:10:41 GMT
server: uvicorn
content-length: 33
content-type: application/json
content-security-policy: default-src 'self'
strict-transport-security: max-age=31536000; includeSubDomains; preload
INFO: Uvicorn running on http://0.0.0.0:8000 (Press CTRL+C to quit)
{"message": "Hello, Secure World"}
GET /ping HTTP/1.1" 200
```

Рисунок 1 – Ответ сервера

ЗАКЛЮЧЕНИЕ

В ходе работы был разработан минимальный сервис на базе FastAPI, включающий один маршрут `GET /ping`. В приложение добавлено `middleware`, устанавливающее защитные заголовки `CSP` и `HSTS`.

Выполнена ручная проверка через `curl`, подтвердившая наличие заголовков и корректность ответа.

Это позволило освоить процесс создания и запуска FastAPI-приложений и изучить механизм внедрения `middleware`.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

1. FastAPI. FastAPI documentation : сайт. – Текст : электронный. – 2025. – URL : <https://fastapi.tiangolo.com/> (дата обращения: 07.09.2025).
2. Mozilla Developer Network. Content-Security-Policy (CSP) : сайт. – Текст : электронный. – 2025. – URL : <https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP> (дата обращения: 07.09.2025).
3. Mozilla Developer Network. HTTP Strict-Transport-Security (HSTS) : сайт. – Текст : электронный. – 2025. – URL : <https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Strict-Transport-Security> (дата обращения: 07.09.2025).
4. Python Software Foundation. Python 3.10 documentation : сайт. – Текст : электронный. – 2025. – URL : <https://docs.python.org/3.10/> (дата обращения: 07.09.2025).

ПРИЛОЖЕНИЕ А

(обязательное)

Листинг А.1 – main.py

```
from fastapi import FastAPI, Request

app = FastAPI()

@app.middleware("http")
async def security_headers(request: Request, call_next):
    response = await call_next(request)

    response.headers["Content-Security-Policy"] = "default-src 'self'" # CSP

    response.headers["Strict-Transport-Security"] = (
        "max-age=31536000; includeSubDomains; preload" # HSTS
    )

    return response

@app.get("/ping")
async def ping():
    # FastAPI сам преобразует в JSONResponse
    return {"message": "Hello, Secure World"}
```

Листинг А.2 – requirements.txt

```
fastapi[standard]
```